

Atlas Auth Service - Architecture & Design

Author: Raj Malhotra, Staff Engineer | Last updated: March 12, 2026 | Status: Living document

1. Overview

Atlas is Nexora's internal authentication and session-management service, powering login, token issuance, and access control for every Nexora product surface, including the Phoenix analytics dashboard and the upcoming Comet mobile app. It is owned by the Atlas team (Raj Malhotra, Aisha Verma, Priya Nair) with Sara Khan as Product Manager, reporting up through Rahul Bose (CTO).

This document describes Atlas's current architecture, recent changes made to resolve production issues, and near-term design decisions.

2. System Components

- Auth API - REST service handling login, token refresh, and logout; built in Python.
- User Store - primary PostgreSQL database holding user records, credentials (Argon2-hashed), and role assignments.
- Session Layer - validates active sessions on every authenticated request (see Section 3 for recent changes).
- Token Service - issues and rotates OAuth2 access and refresh tokens (see ATL-101, completed Jan 2026).

3. Session Management

Historically, every authenticated API request triggered a full lookup against the primary users table in PostgreSQL to validate the session. This was simple to reason about but did not scale well under concurrent load.

In early March 2026, Aisha Verma flagged (ticket ATL-104) that users were experiencing 2-3 second login delays during the 9-10 AM IST peak traffic window. Investigation confirmed the root cause was this per-request database lookup pattern.

Decision (Atlas Weekly Sync, March 10, 2026): rather than adding a database index as a stopgap, the team chose to introduce a Redis-backed session cache. On login, a session token is written to Redis with a short TTL; subsequent requests validate against Redis instead of hitting PostgreSQL directly. This removes the database from the hot path entirely for session checks.

A managed Redis instance is being provisioned by Devansh Gupta (Platform Infra Review, March 5, 2026) ahead of this rollout. This Redis session layer is also expected to be reused by the Comet mobile app's auth flows, per the January 15, 2026 Comet Kickoff decision to share authentication infrastructure across products rather than building a parallel system.

4. Security Considerations

- Password hashing migration from bcrypt to Argon2id is in progress (ATL-103), targeting production rollout by mid-March 2026.
- Rate limiting was added to the login endpoint (ATL-102) after a security scan flagged brute-force risk.

- Refresh tokens rotate on every use (ATL-101) to reduce the blast radius of a leaked token.
- SSO (SAML) support is being scoped for enterprise clients (ATL-106) following a request routed through Neha Joshi's sales team.

5. Rollout Plan

- Week of Mar 11: Redis instance provisioned (owner: Devansh Gupta).
- Week of Mar 12-17: Session layer migrated to Redis-backed validation, feature-flagged for gradual rollout (owner: Raj Malhotra).
- Week of Mar 17: Argon2 migration shipped to production (owner: Priya Nair).
- Post-rollout: monitor login latency dashboards to confirm the peak-hour delay reported in ATL-104 is resolved.